Nathaly Flores
CYSE 625
Term: (Fall) 2022

Laboratory Exercise C1 – Advanced Port Scanning

Due Date: 09/14/2022
Points Possible: Number of points out of total course points or recommended percent of the course grade.

1. Overview

In this lab, students will learn how Metasploit and Nmap can be used in combination to streamline the scanning process. Students will learn how to find open ports, how to find the services running on those ports, how to further enumerate discovered ports, and how to save the results for reporting. For this lab, students will use the Cyber Range: Environment: Kali Linux with Metasploitable (2020.09) environment to perform port scanning and enumeration.

2. Resources Required

This exercise requires a Kali Linux VM running in the Cyber Range.

[Note to instructors: This lab exercise requires an account on the Cyber Range. To sign up for an account on The Range, please visit our Sign-Up page. Your students will also require an account on the Cyber Range; this will be explained in the setup of your course.]

3. Initial Setup

For this exercise, you will log in to your Cyber Range account and select the Environment: Kali Linux with Metasploitable (2020.09), then click "start" to start your environment and "join" to get to your Linux desktop login. Log in using these credentials:

Username: **`student`**
Password: **`student`**

4. Tasks

Task 1: Advanced command line scanning with Nmap and Metasploit

Review and refer to the following Nmap cheat sheets during this lab:

- cheatsheet from SANS
- StationX

Complete the following:

1. Open a terminal window.
2. Type `sudo su` to become root.
3. Type `service postgresql start` since Metasploit uses the PostgreSQL database.
4. Type `msfdb init` to initialize the Metasploit database.
5. Type `msfconsole` to start the Metasploit framework.
6. Type `db_status` to verify that the database has connectivity. You should see the "[*] postgresql connected to msf" message as displayed on the below image.

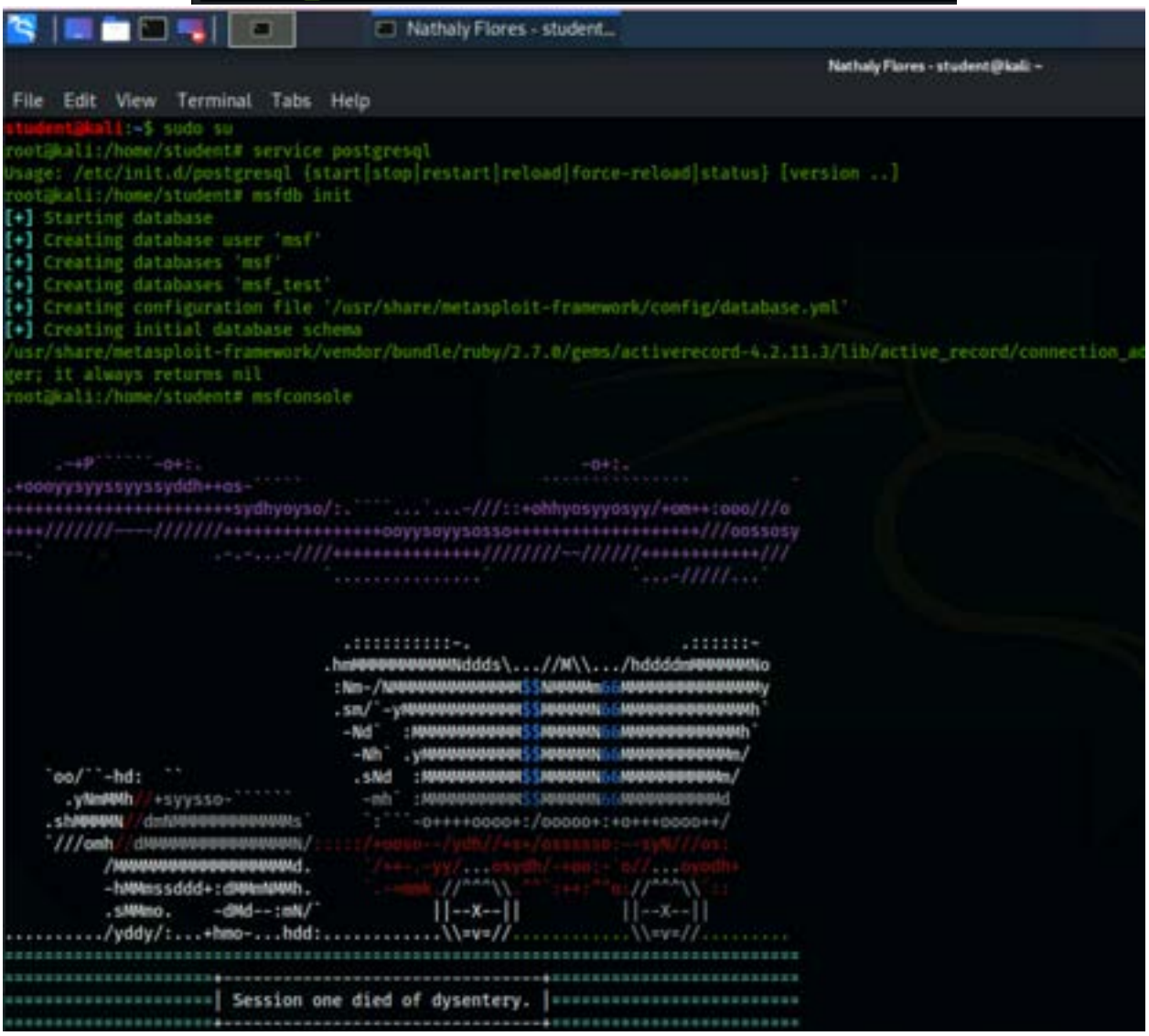
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

[Any blue text should be replaced by instructor using material and font color changed to black.]

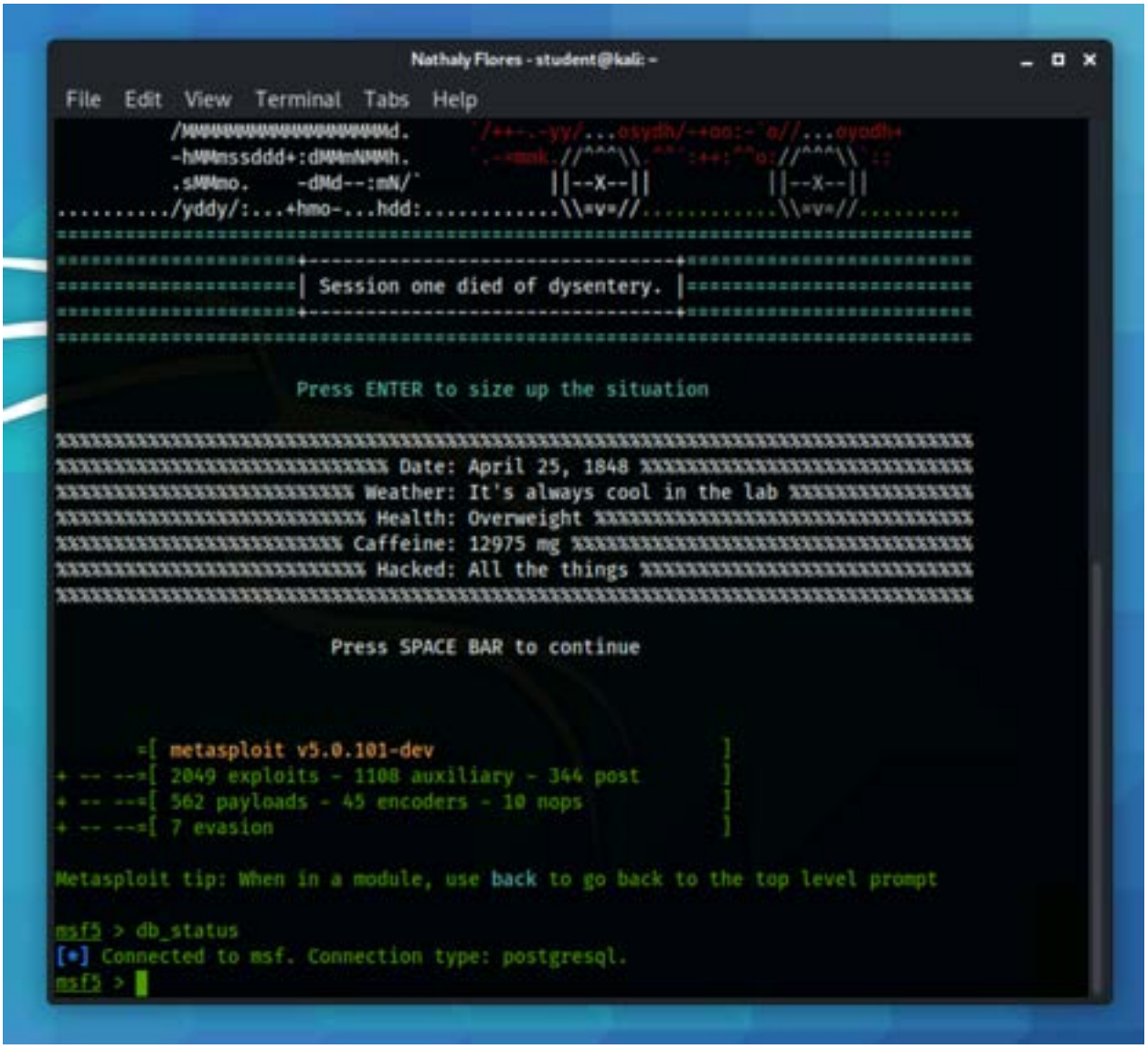
Course Title

Term: (Fall, Spring, Summer, Winter) 20XX

```
msf5 > db_status
[*] Connected to msf. Connection type: postgresql.
msf5 >
```



© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



If the database does not have connectivity or you accidently started the framework before starting the database, exit out of the terminal and repeat step 1, 2, 5, and 6. This should do the trick. If for some reason it does not, exit out of the terminal and complete steps 1-6 again.

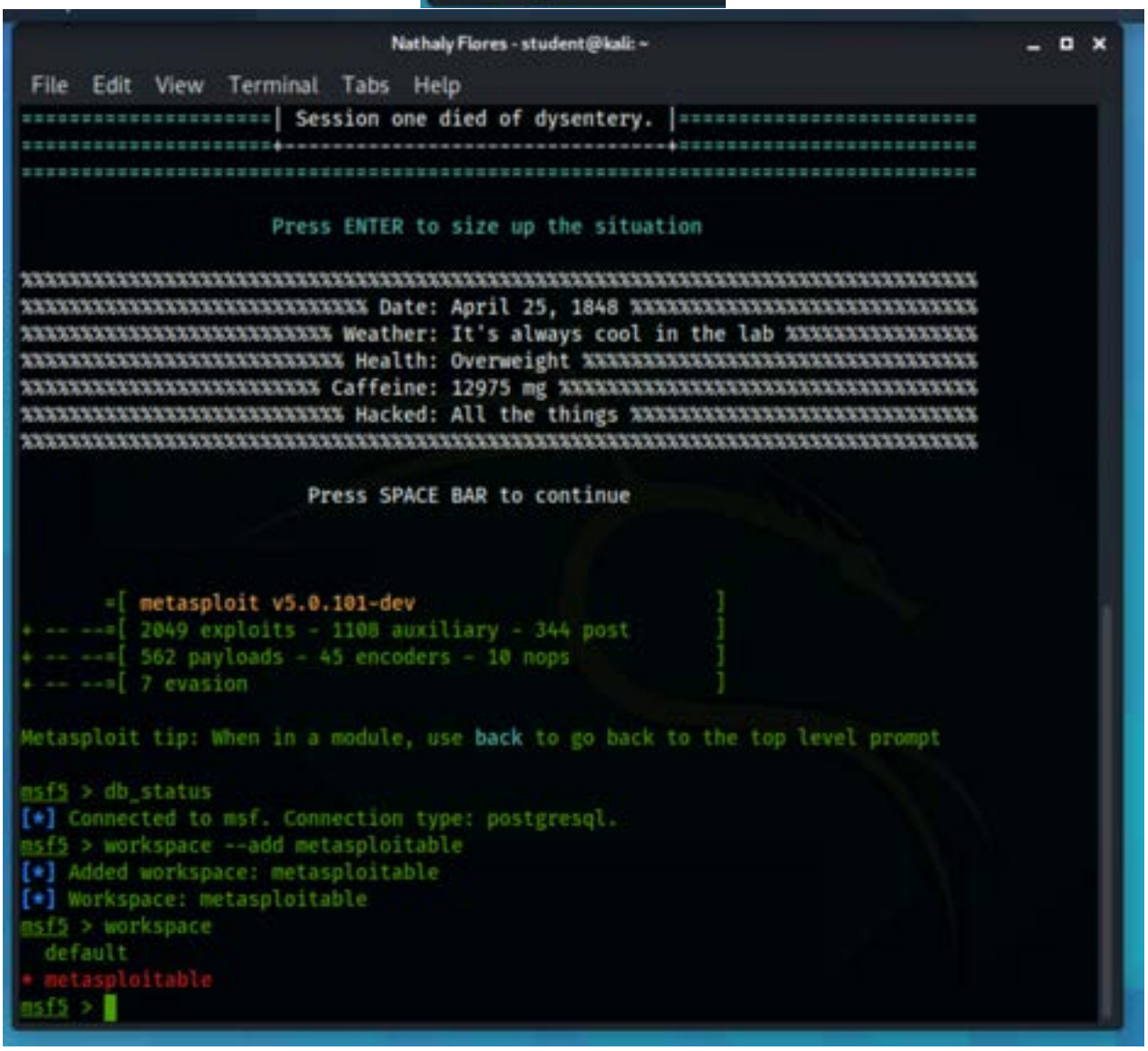
Before we start scanning, we want to create a workspace for our scans. This will make it easier to find the scans at a later time when we complete our reports. It will also prevent the issue of polluting the database when we need to work on more than one project.

Complete the following:

1. Type `workspace --add metasploitable` and press enter.
2. Type `workspace` to verify you are working in the metasploitable workspace. There will be an asterisk followed by the word “metasploitable” in red font as you see in the below image.

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

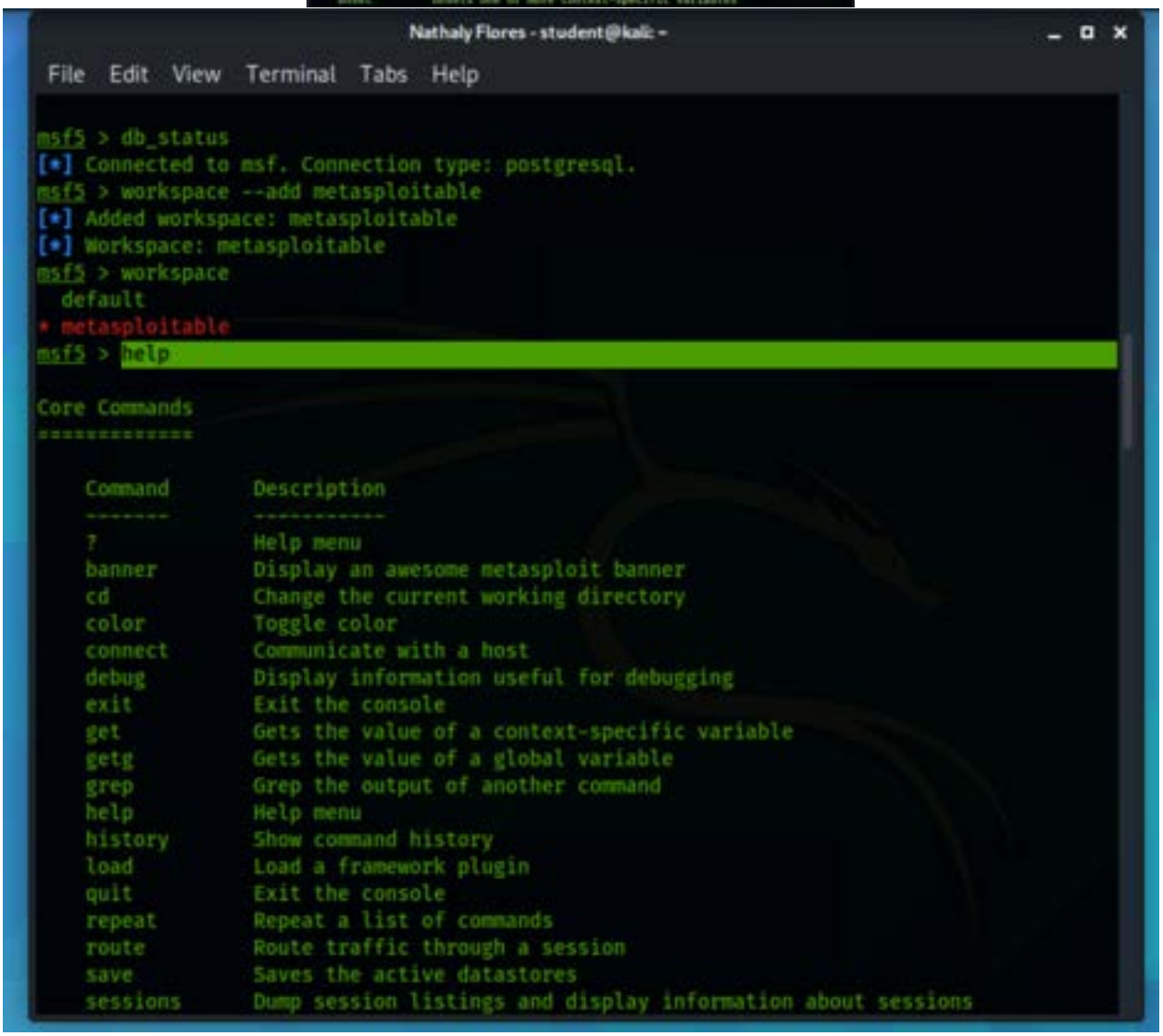
```
msf5 > workspace
  default
* metasploitable
msf5 >
```



We have now created our very own workspace. Our scans will be saved automatically in the workspace. To check the Database Backend Commands, type `help`.

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)





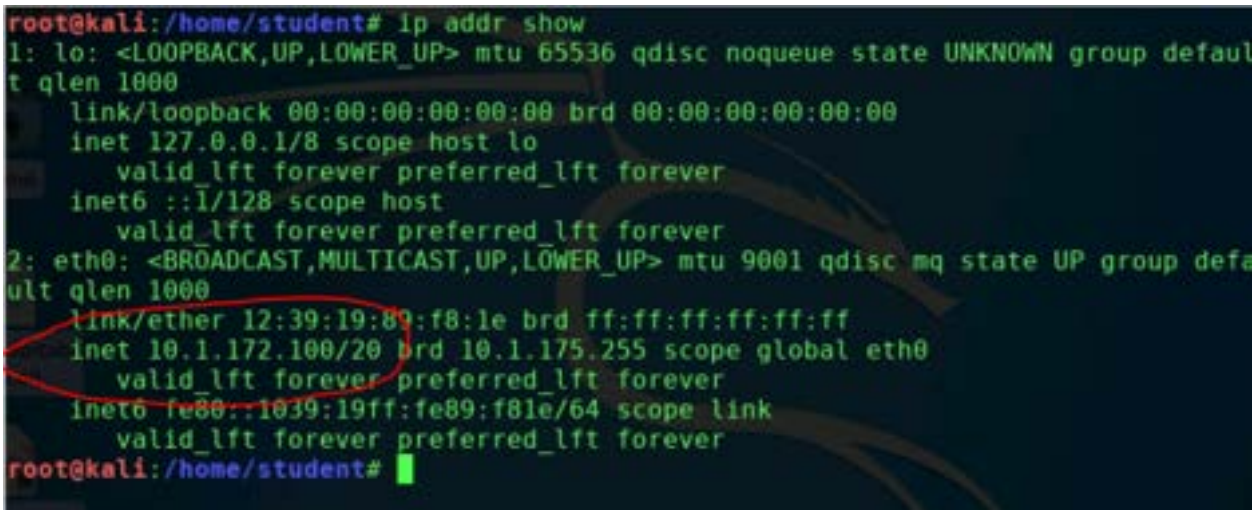
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

Take notice of the **hosts**, **services**, and **notes**. We will be calling on these when we write reports or when we pick up where we left off. This way we do not have to complete the scans again. They are all saved in the workspace database.

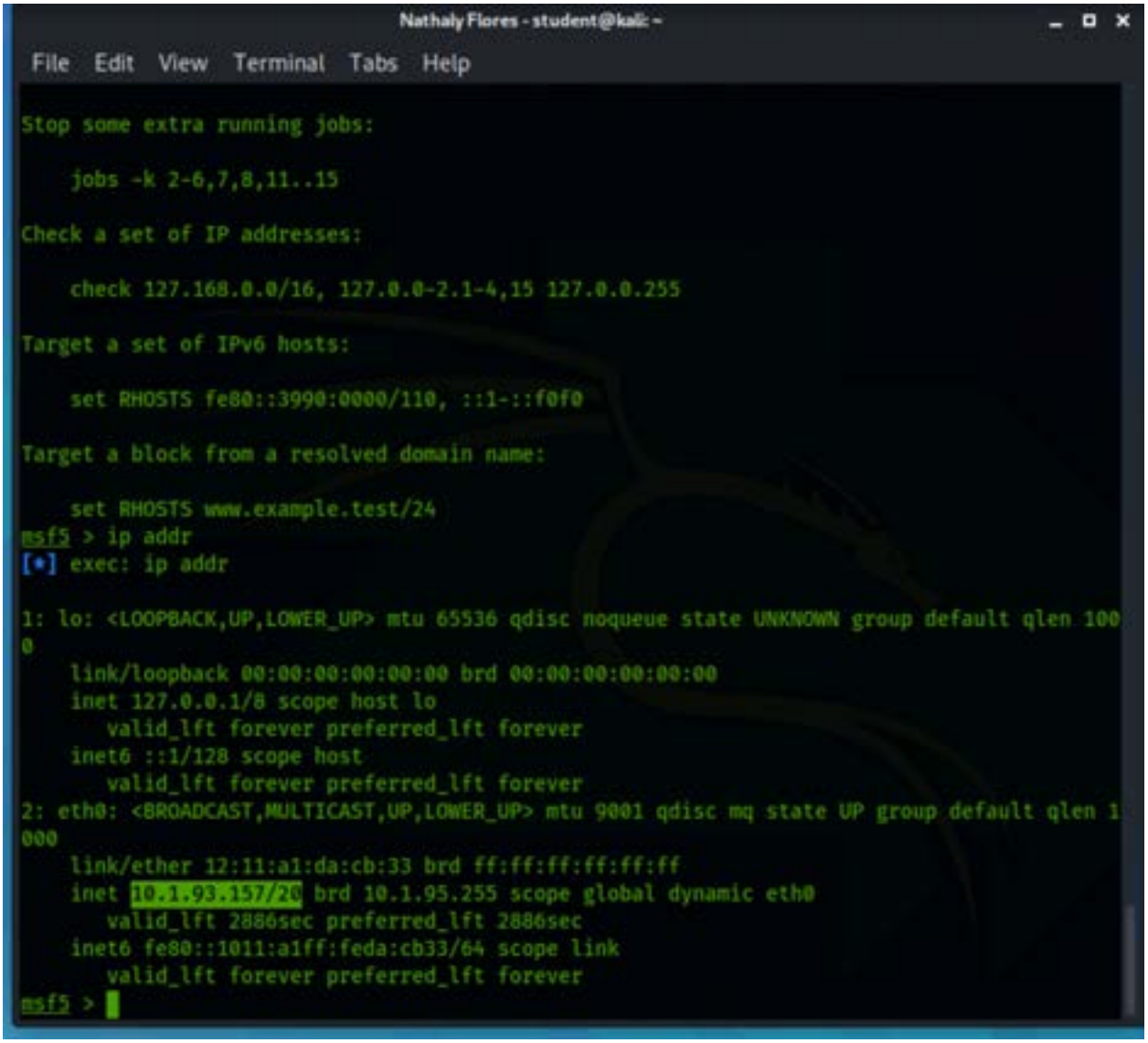
Now we are ready to start scanning the system. There are several ways to discover hosts. Different tactics are used if ports are filtered. We are trying to find a specific target that is holding the Metasploitable 3 content. Below are several ways to complete the task. I encourage you to try them all, if time permits. We will start with a few simple commands and scans first as a brief refresher.

Complete the following:

1. Type `ip addr show` to discover your current network configurations.
2. Write down in space provided or take note of your IP: __10.1.93.157/20.



© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

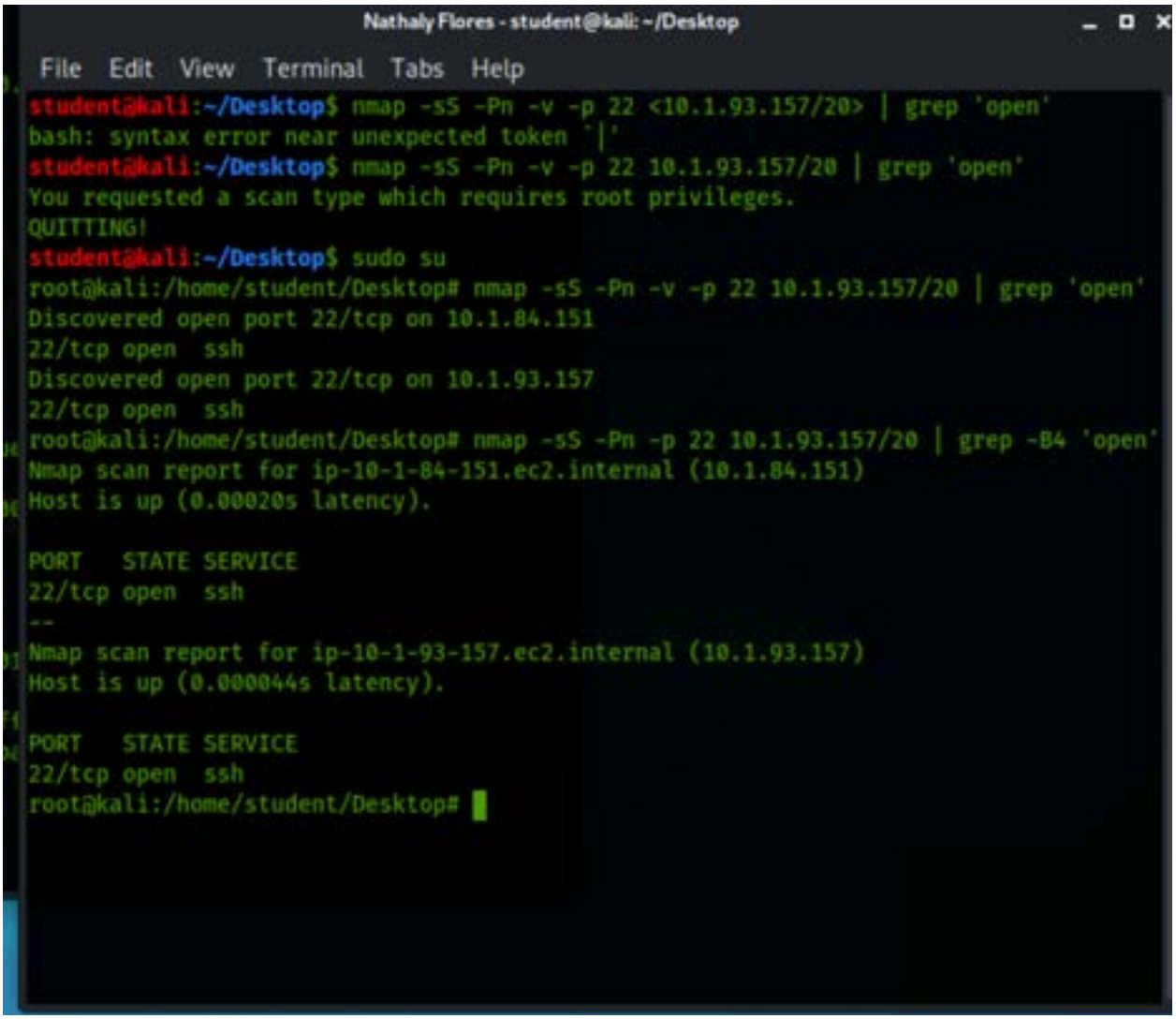


This is our machine, but we have also discovered the subnet with this tactic. In future scans we don't really want to scan ourselves. We can exclude this machine with `--exclude <ip address>` in our scans. It is a good idea to remember this as in many situations your host will have many ports and services that can be found. Thus, polluting the results. Take a screenshot and name it *1ipaddrshow*. Save it in a folder named scanning.

The following commands will help you find the target Metasploitable machine. Open a new terminal window and become root. Type the following:

1. `nmap -sS -Pn -v -p 22 <your IP/20> | grep 'open'`
   `-discovered open ports 1. 22/tcp on 10.1.84.151 and 22/tcp on 10.1.93.157 ssh`
2. `nmap -sS -Pn -p 22 <your IP/20> | grep -B4 'open'`
   `ip-10-1-93-157.ec2.internal (10.1.93.157).`
3. Write down the IP address or copy and paste it into your notes

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

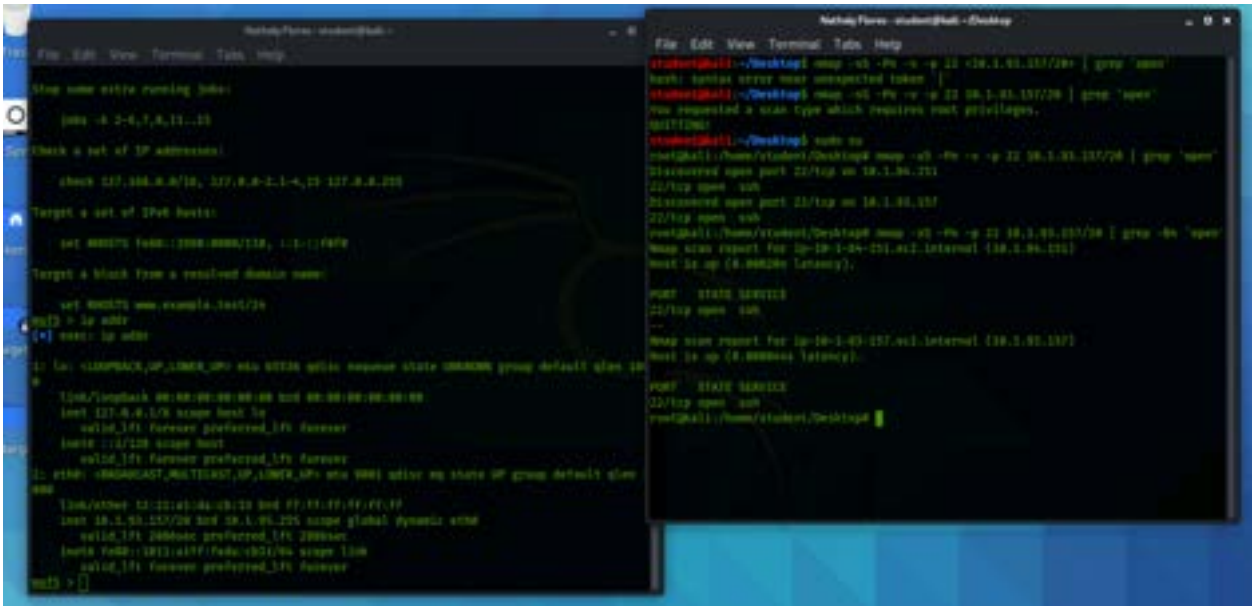


The reason this works is because we disable ping, and know that port 22 is open only on a few machines. The /20 scans the subnet but is much faster if we only scan port 22. The first command shows verbosity (the amount that is printed to the display while the command is running) and pipes that into grep, and searches for "open " ones. The second command drops verbose and adds -B4 which shows the 4 lines before the regex match. Scanning the entire subnet with -p- will take about 20 minutes. Where the other scans take about 10 seconds. You can streamline your pentesting processes by knowing more about powerful Linux tools like grep and Nmap.

Answer the following questions:

1. What is the host IP on the Metasploitable machine (every student will have a different IP)?
   10.1.84.151
2. Take a screenshot of the results name it *2target* and save it in the scanning folder.

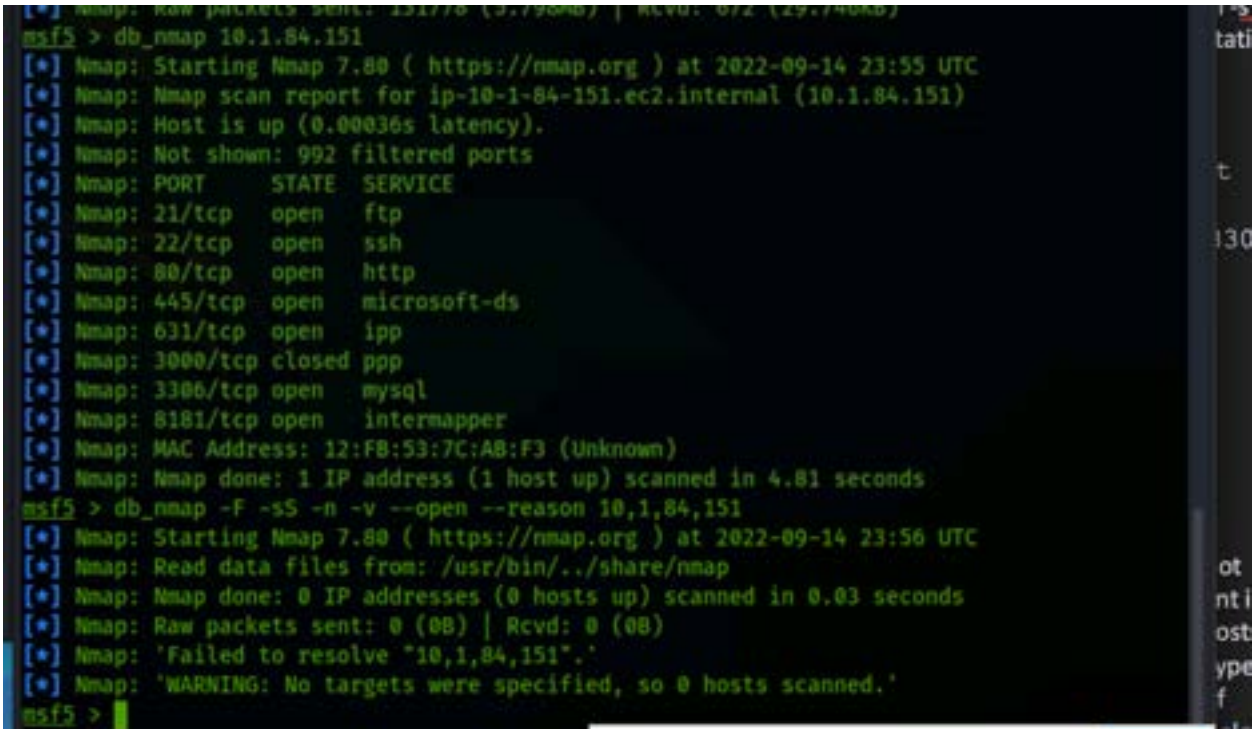
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



Task 2: Discovering open ports and services with Metasploit and Nmap

Return to the terminal window with the Metasploit Framework running, at the msf5> prompt complete the following:
[IMPORTANT: My Metasploitable IP is 10.1.163.125; everywhere you see this replace it with your Metasploitable IP.]

1. Type `db_nmap 10.1.163.125` and press enter.



2. Type `db_nmap -F -sS -n -v --open --reason 10.1.163.125` and press enter.

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

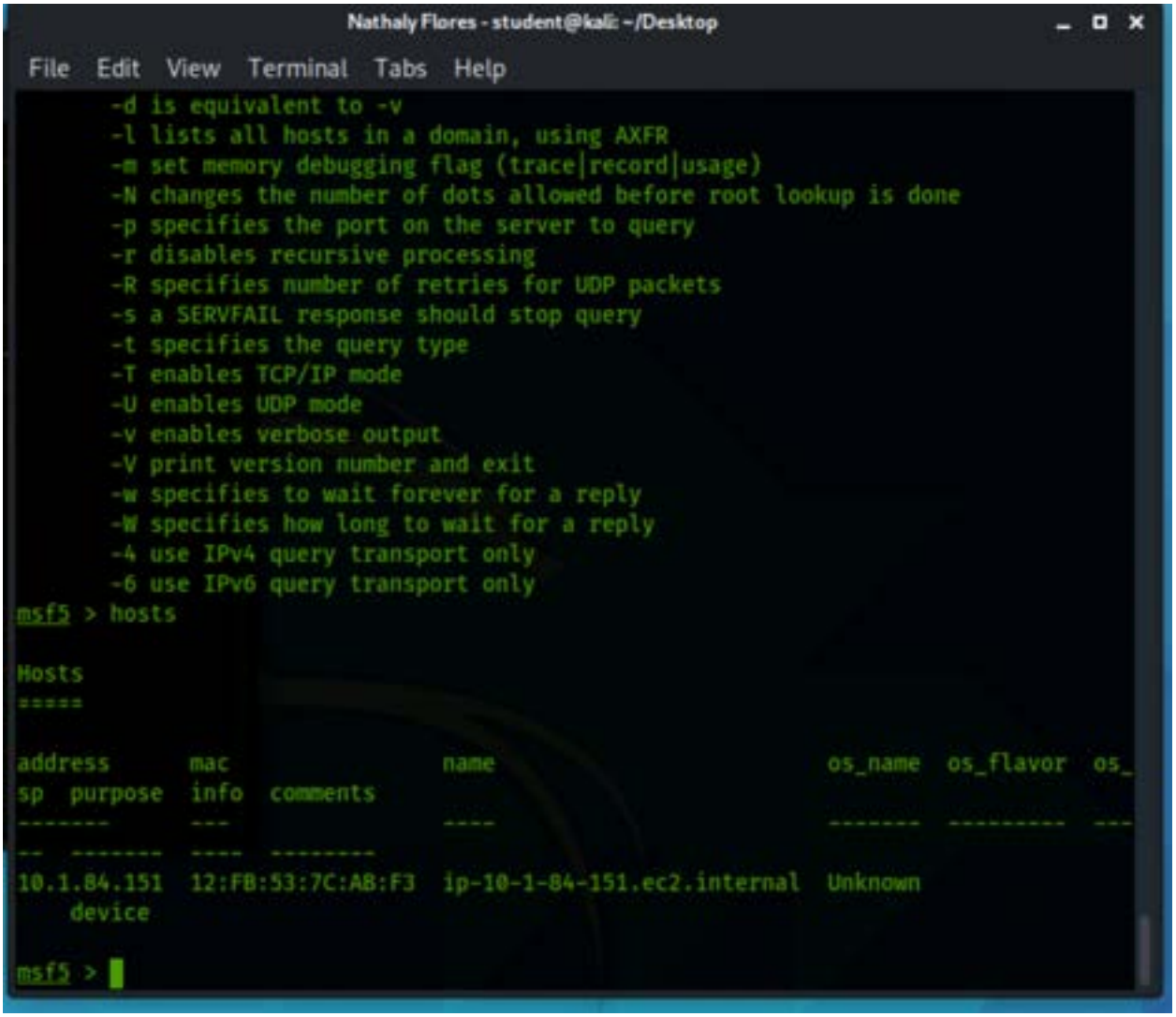
```
msf5 > db_nmap -F -sS -n -v --open --reason 10.1.84.151
[*] Nmap: Starting Nmap 7.80 ( https://nmap.org ) at 2022-09-15 00:21 UTC
[*] Nmap: Initiating ARP Ping Scan at 00:21
[*] Nmap: Scanning 10.1.84.151 [1 port]
[*] Nmap: Completed ARP Ping Scan at 00:21, 0.03s elapsed (1 total hosts)
[*] Nmap: Initiating SYN Stealth Scan at 00:21
[*] Nmap: Scanning 10.1.84.151 [100 ports]
[*] Nmap: Discovered open port 21/tcp on 10.1.84.151
[*] Nmap: Discovered open port 3306/tcp on 10.1.84.151
[*] Nmap: Discovered open port 80/tcp on 10.1.84.151
[*] Nmap: Discovered open port 22/tcp on 10.1.84.151
[*] Nmap: Discovered open port 445/tcp on 10.1.84.151
[*] Nmap: Discovered open port 631/tcp on 10.1.84.151
[*] Nmap: Completed SYN Stealth Scan at 00:21, 1.67s elapsed (100 total ports)
[*] Nmap: Nmap scan report for 10.1.84.151
[*] Nmap: Host is up, received arp-response (0.00043s latency).
[*] Nmap: Not shown: 93 filtered ports, 1 closed port
[*] Nmap: Reason: 93 no-responses and 1 reset
[*] Nmap: Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
[*] Nmap: PORT     STATE SERVICE      REASON
[*] Nmap: 21/tcp   open  ftp          syn-ack ttl 64
[*] Nmap: 22/tcp   open  ssh          syn-ack ttl 64
[*] Nmap: 80/tcp   open  http         syn-ack ttl 64
[*] Nmap: 445/tcp  open  microsoft-ds syn-ack ttl 64
[*] Nmap: 631/tcp  open  ipp          syn-ack ttl 64
[*] Nmap: 3306/tcp open  mysql        syn-ack ttl 64
[*] Nmap: MAC Address: 12:FB:53:7C:AB:F3 (Unknown)
[*] Nmap: Read data files from: /usr/bin/../share/nmap
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 1.81 seconds
[*] Nmap: Raw packets sent: 194 (8.520KB) | Rcvd: 8 (332B)
```

Command breakdown:

- `-F` is a fast scan of top 100 ports
- `-sS` is a syn scan or TCP port scan
- `-n` for host discovery; do not resolve DNS
- `-v` this increases the verbosity level (how much is printed to your display) use –vv for greater effect
- `--reason` this will output the reason a port is its current state
- `--open` this will show only open ports

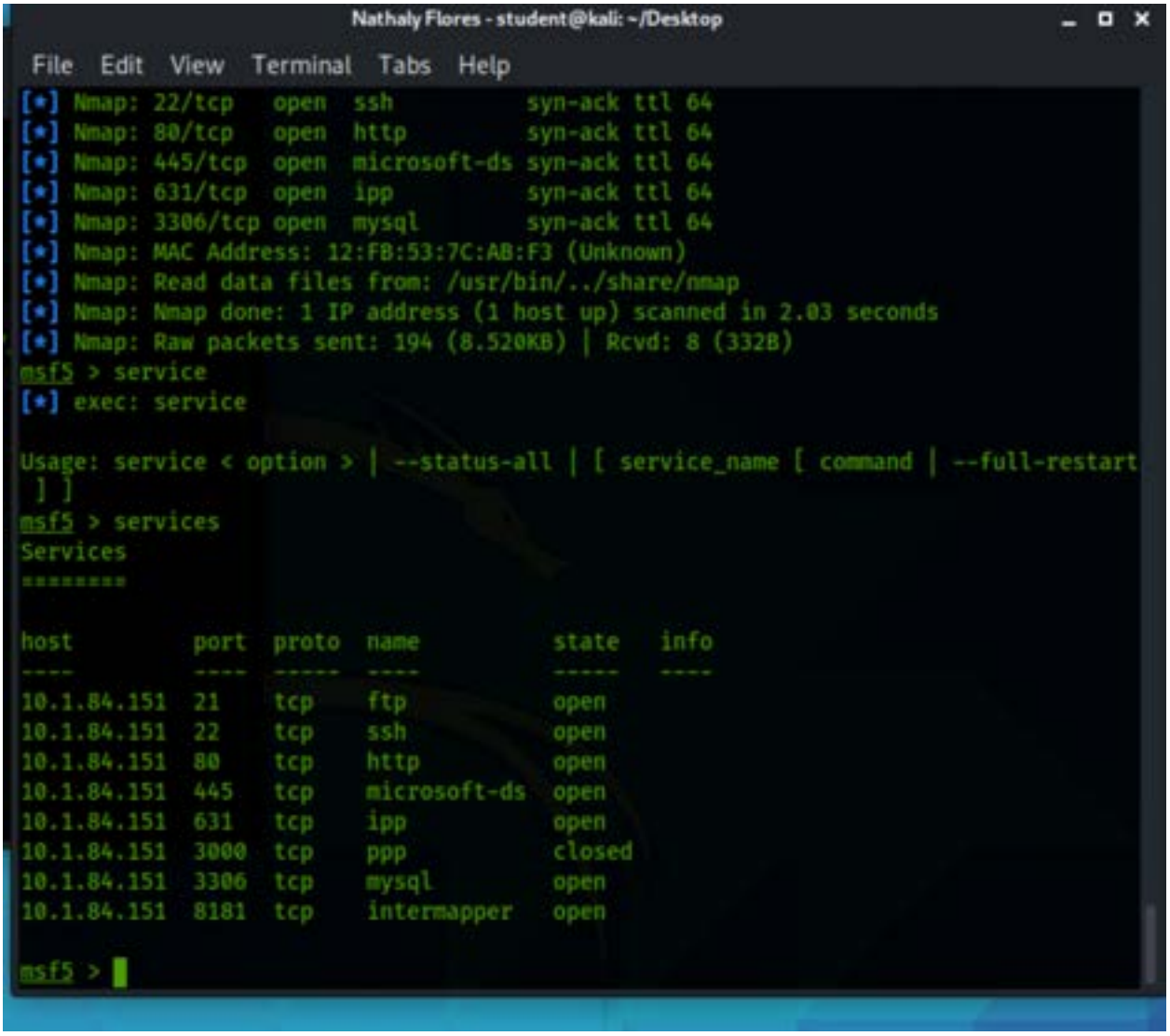
To view current host results stored in your workspace type `hosts`.

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



To view the current services stored in your workspace type `services`.

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



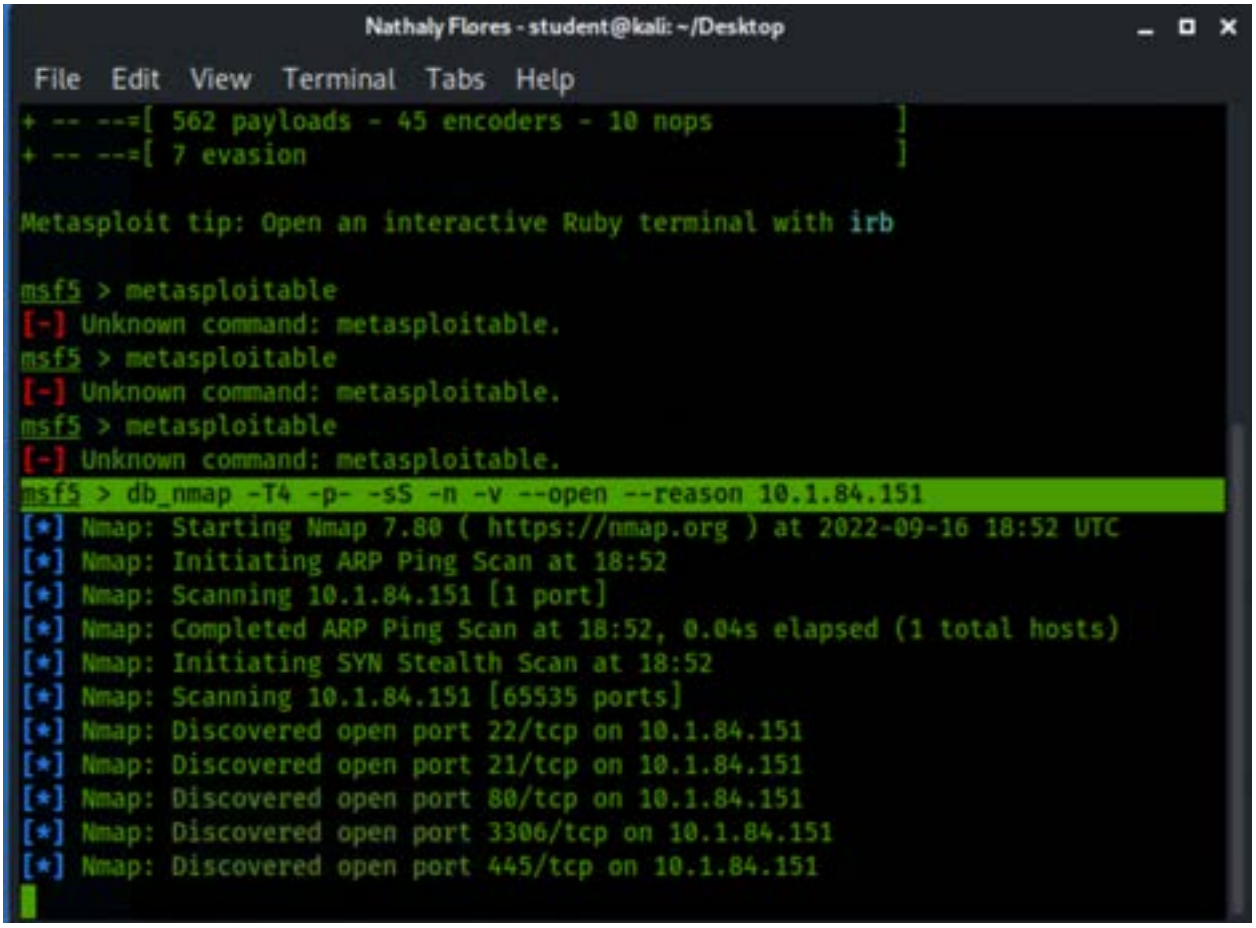
We could scan for all the ports on the host instead of only the top 100 by using a `-p-` instead of `-F`; however, this would take some time. Note that the environment in the Cyber Range is always changing. If this scan is taking too long, it can be terminated early with CTRL+c. If this is the case, you may not be able to answer the questions.

Open a new terminal window and complete the following:

1. Type `sudo su` and press enter.
2. Type `msfconsole` and press enter.
3. Type `workspace metasploitable` and press enter.
4. Type `db_nmap -T4 -p- -sS -n -v --open --reason <target IP>` and press enter.

Now we can continue with other scans while this one scans in the background.

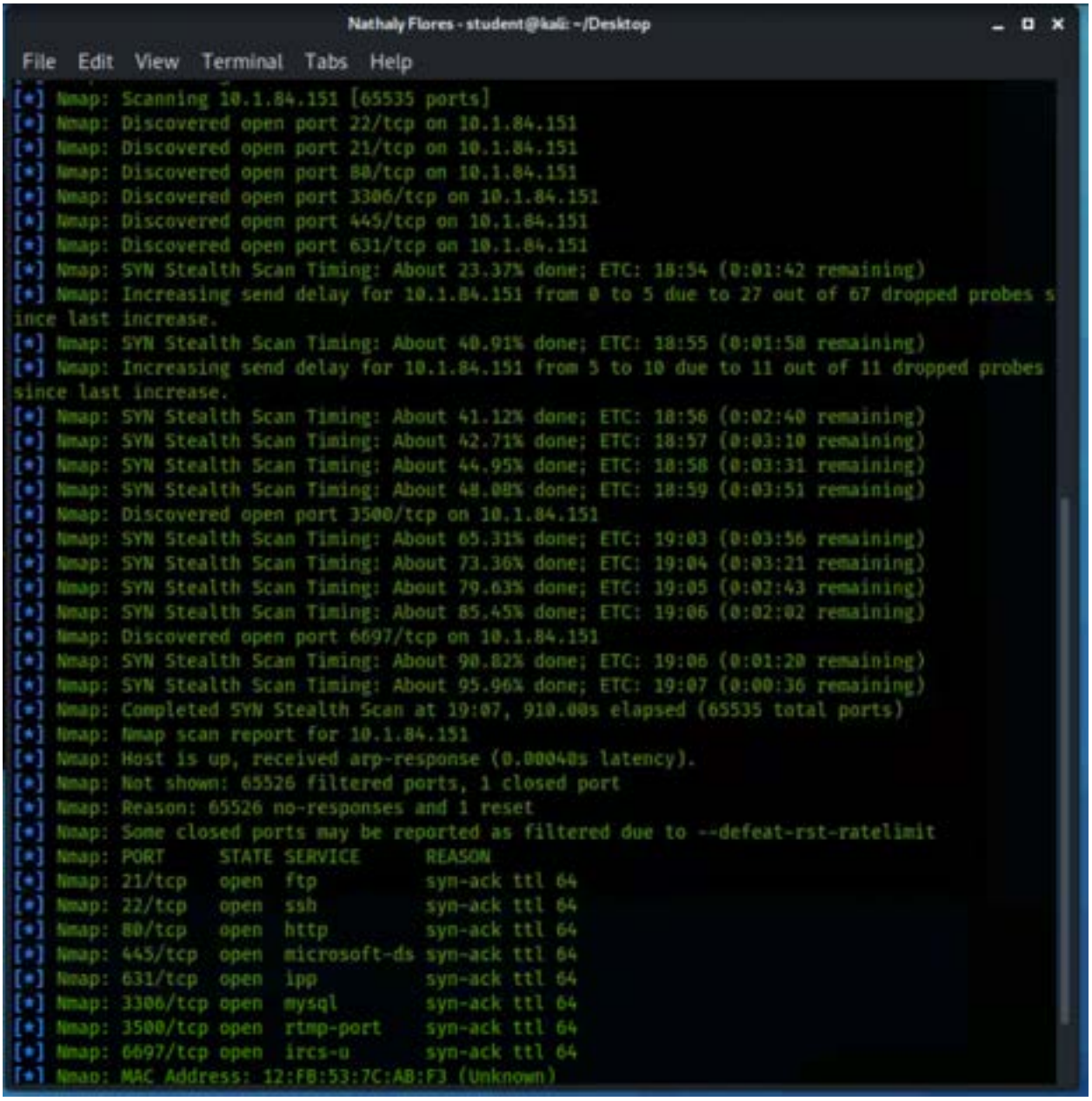
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



Answer the following questions:

1. What services did you find and what ports were running? See the screenshot. Below it shows the services and ports that are running.

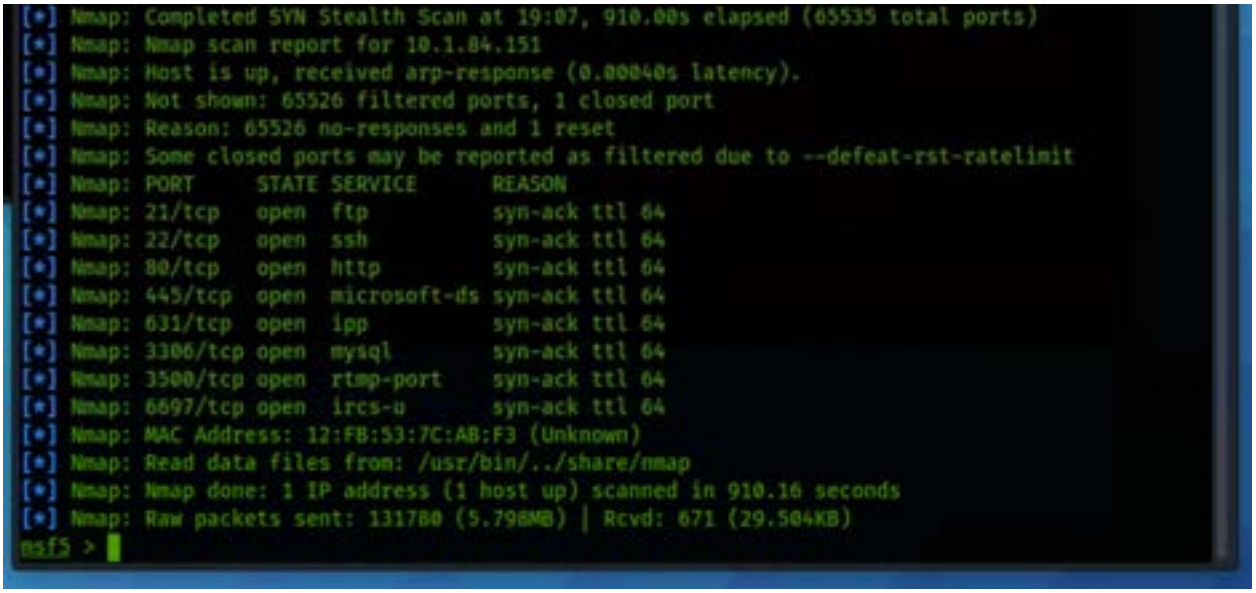
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



2. Take a screenshot of the results name it *3ServicesPorts* and save it in the scanning folder.

These are the results of the folder 3ServicesPorts below save onto this assignment.

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



Task 3: Run a UDP scan using Metasploit and Nmap

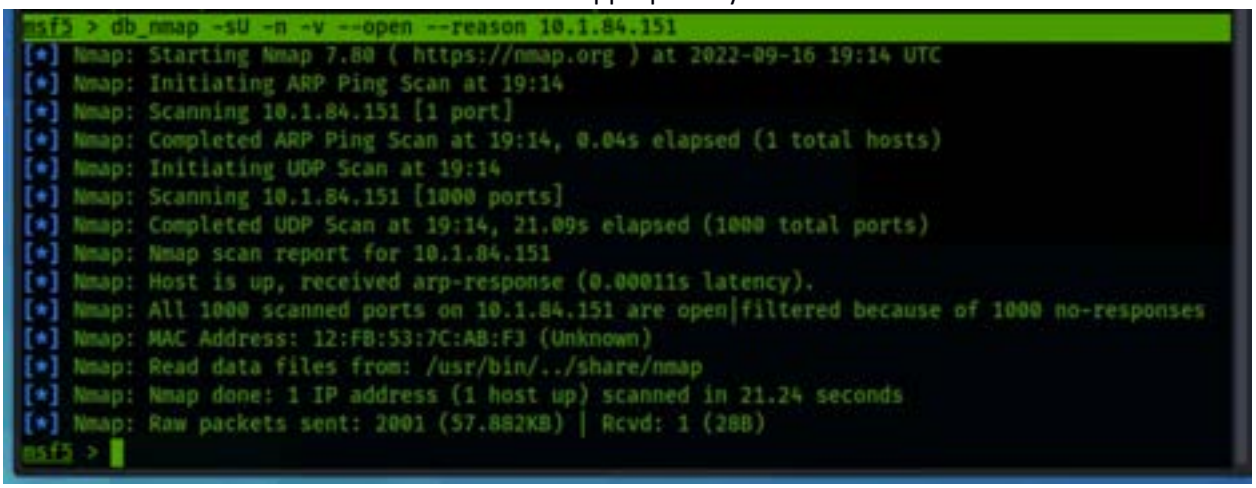
If there were an SNMP (Simple Network Management Protocol), NetBIOS, or ISAKMP/IKE service running, performing a UDP scan can discover this. The switch -sU is a UDP scan.

Complete the following:

1. Type `db_nmap -sU -n -v --open --reason <target IP>` and press enter.

Answer the following questions:

1. What services did you find? ARP Scan, Ping
2. Take a screenshot of the results name it appropriately. See the screenshot below



Task 4: Service Version Scanning

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

Before we continue, we want to get more information on the services that are running. The switch -sV will search for service versions, and the -sC will use default scripts (OS detection, service, fragmentation) and is considered invasive. You can view the default scripts here.

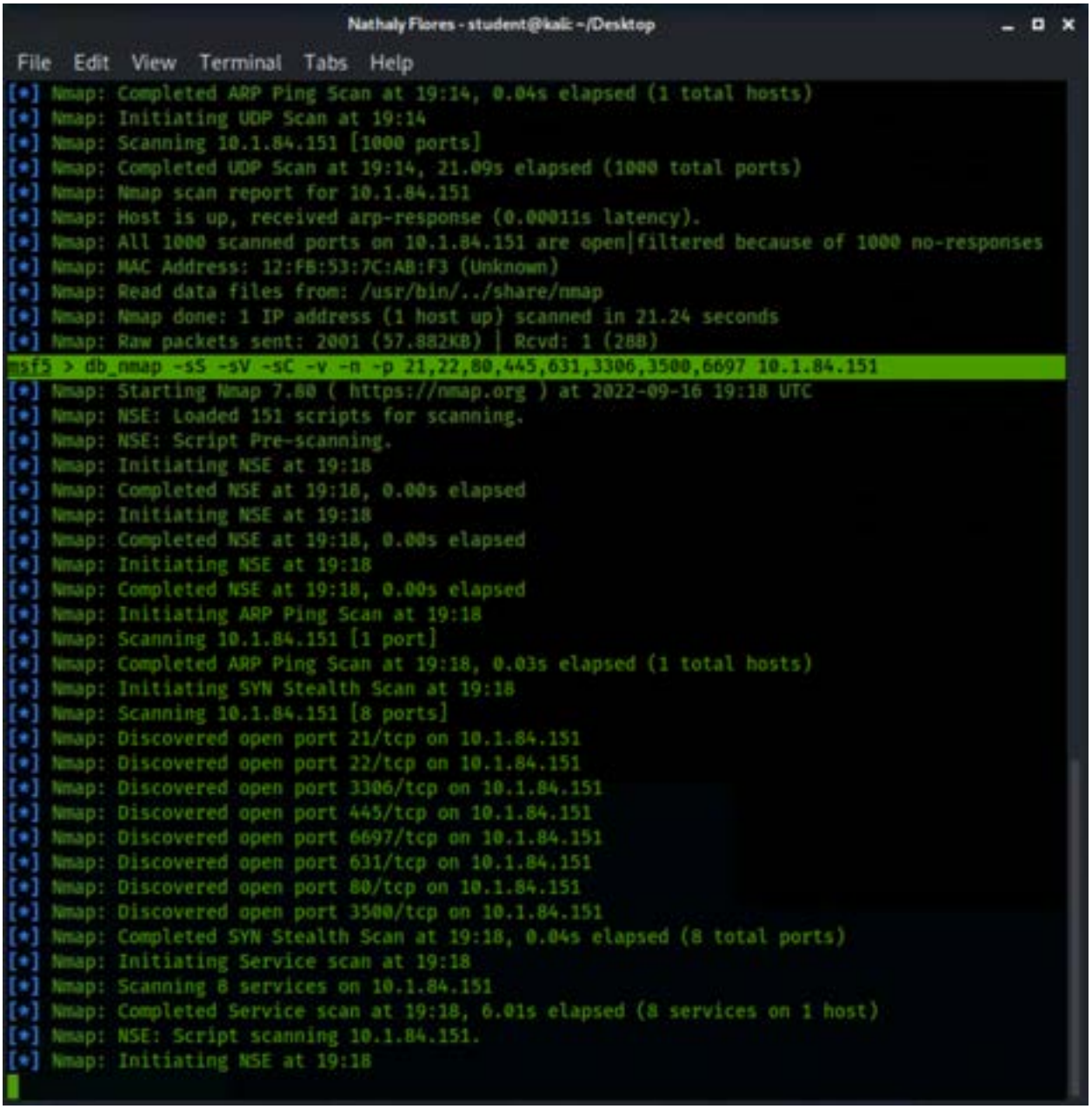
Complete the following:

1. Type `db_nmap -sS -sV -sC –v –n –p <list of ports found> <target IP>` and press enter.
2. My Example: `db_nmap -sS -sV -sC -v -n -p 21,22,80,445,631,3000,3306,8181,3389,8484,8585,9200,49153,49202,49203 10.1.163.125`

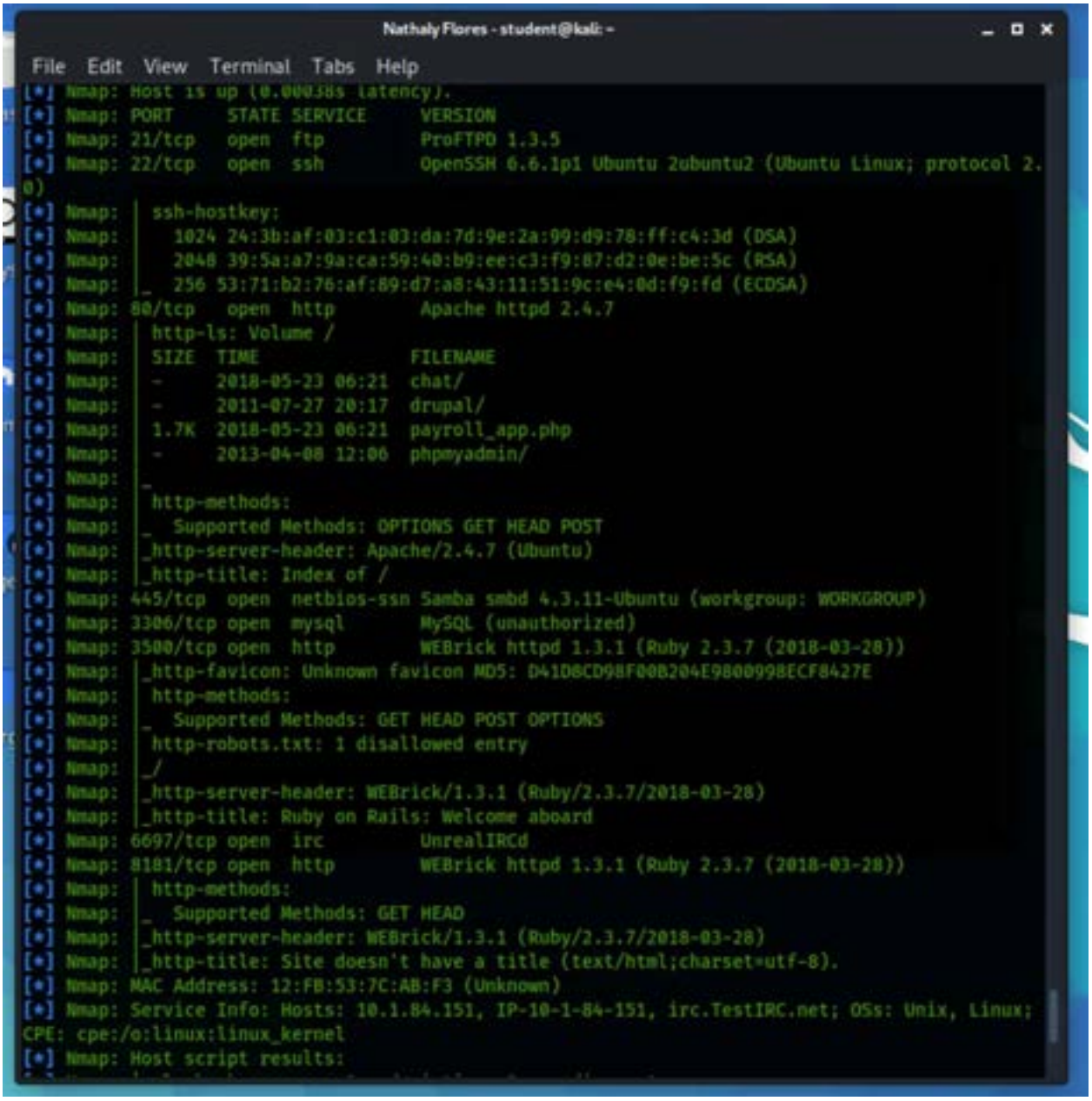
Answer the following questions:

1. What new information was discovered? It is checking all ports that was entered also it give a ping to all of them and time is being completed
2. Take a screenshot of the results and name it appropriately.

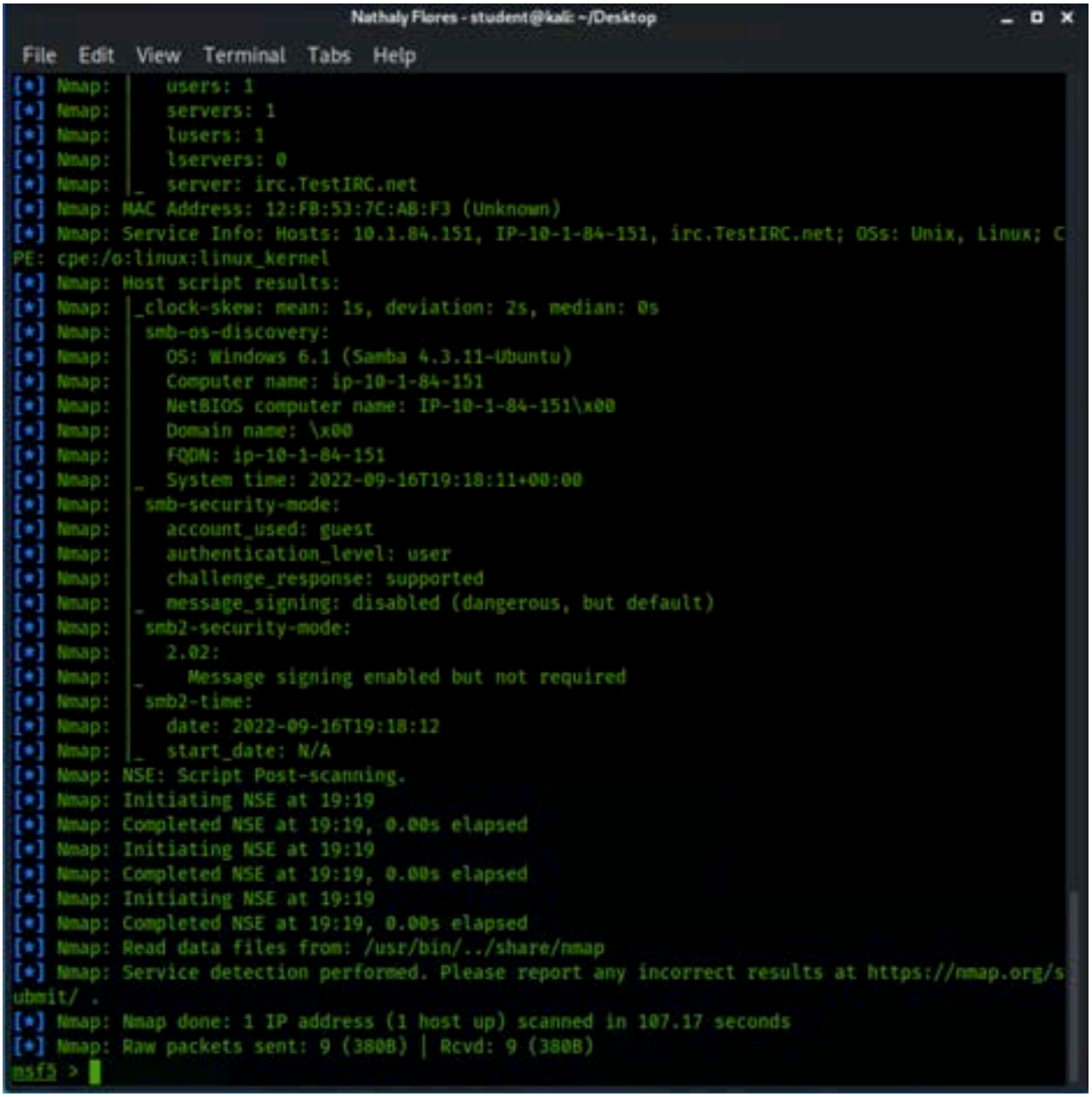
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



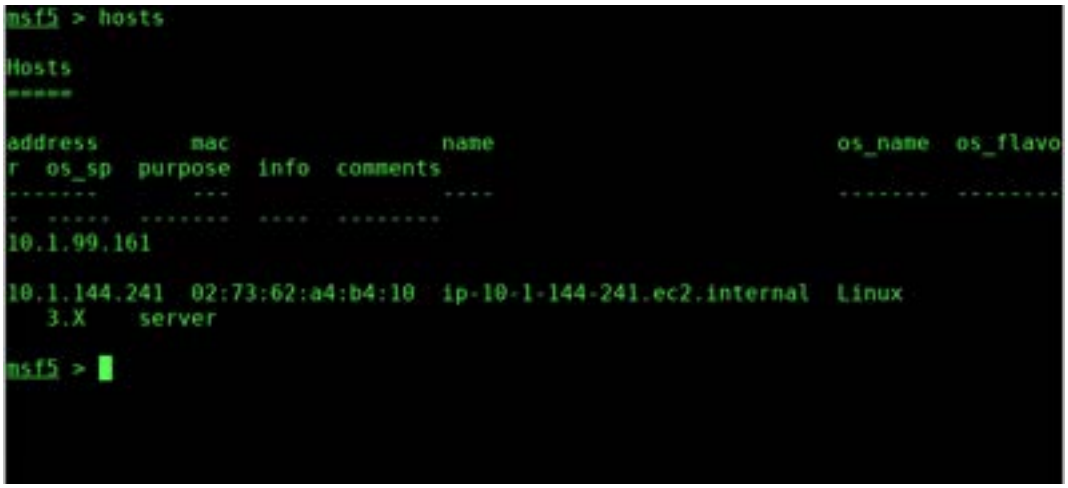
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

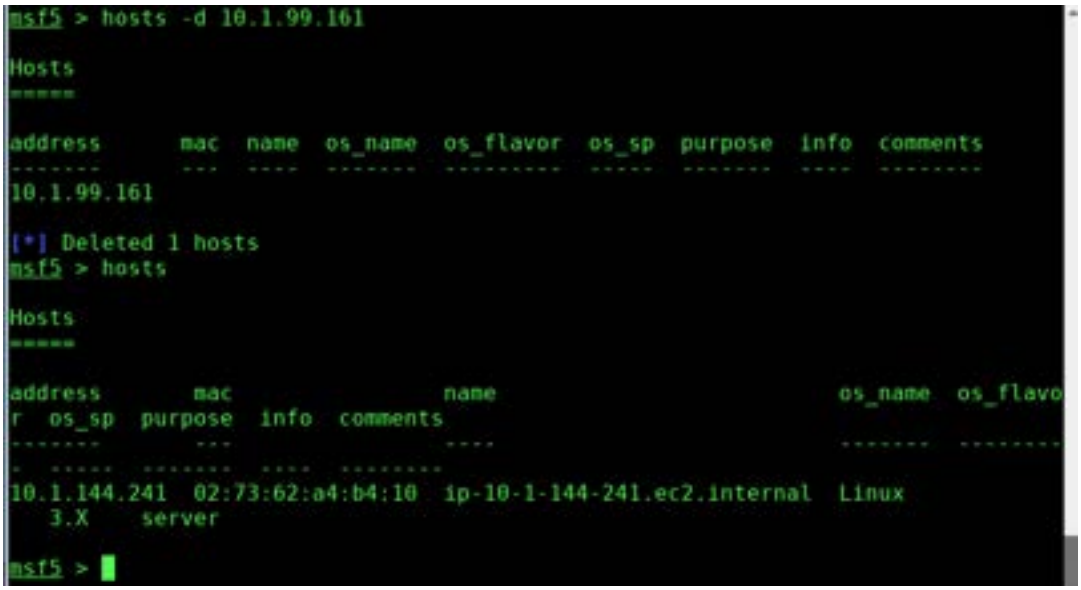


Task 5: Cleaning up your hosts list

So, now that we have completed several scans, we may want to clean up our hosts list. If you do not have any extra hosts, this part of the lesson is for information purposes only. The only host we want in the list is the Metasploitable machine. To do this, we type `hosts` in the msfconsole to view our hosts. If we have any hosts other than our Metasploitable target, they need to be deleted. To do this, we type `hosts -d <host IP we want deleted>`. Once we have deleted the hosts that are out of scope, we should be left with only the Metasploitable host. In my case, that is 10.1.163.125. The below screenshots are examples of how to delete out of scope hosts. For the first two screenshots, the only IP in scope is the Linux Server. The last screenshot is of the Metasploit services database found by typing `services` and pressing enter in the msfconsole.

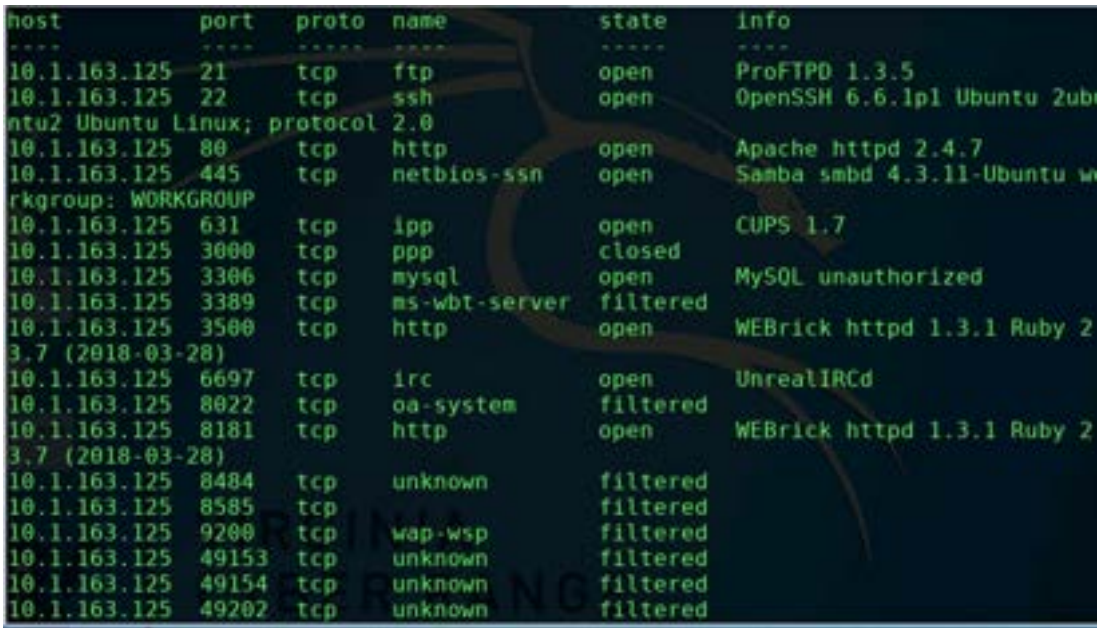
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)





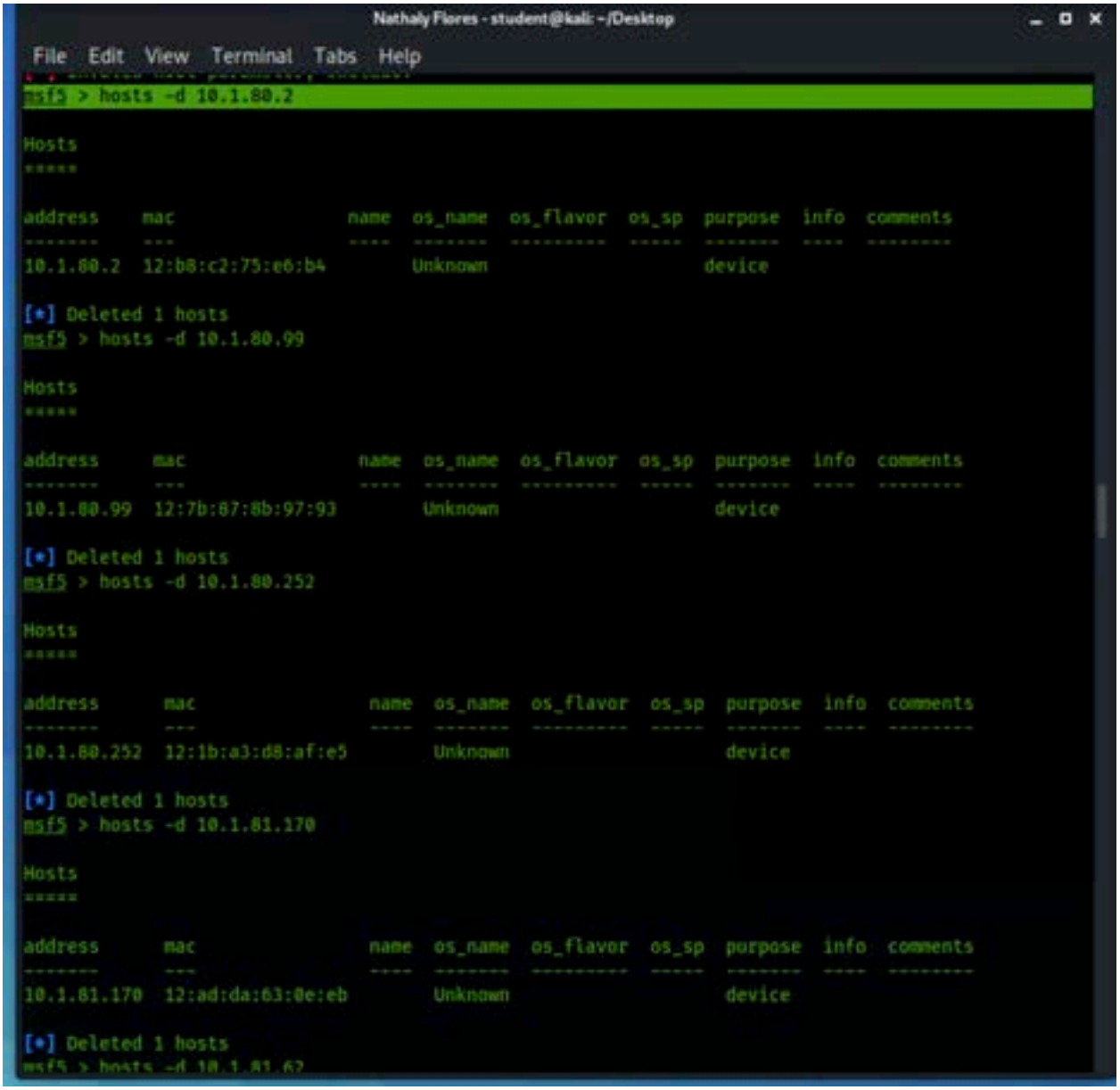
© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)

Services

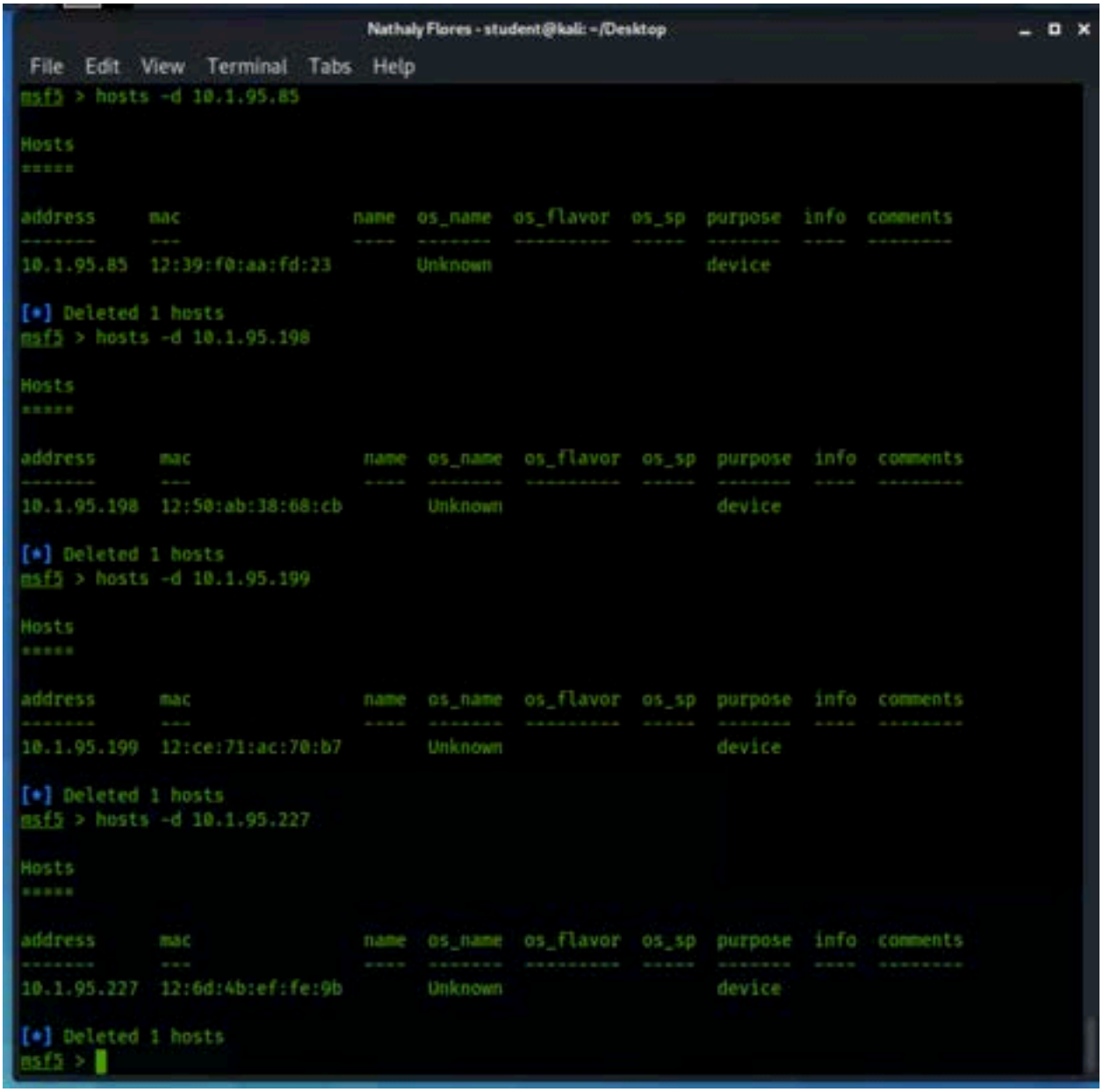


```
host          port   proto  name           state     info
----          ----   -----  ----           -----     ----
10.1.163.125  21     tcp    ftp            open      ProFTPD 1.3.5
10.1.163.125  22     tcp    ssh            open      OpenSSH 6.6.1p1 Ubuntu 2ub
ntu2 Ubuntu Linux; protocol 2.0
10.1.163.125  80     tcp    http           open      Apache httpd 2.4.7
10.1.163.125  445    tcp    netbios-ssn    open      Samba smbd 4.3.11-Ubuntu w
rkgroup: WORKGROUP
10.1.163.125  631    tcp    ipp            open      CUPS 1.7
10.1.163.125  3000   tcp    ppp            closed
10.1.163.125  3306   tcp    mysql          open      MySQL unauthorized
10.1.163.125  3389   tcp    ms-wbt-server  filtered
10.1.163.125  3500   tcp    http           open      WEBrick httpd 1.3.1 Ruby 2
3.7 (2018-03-28)
10.1.163.125  6697   tcp    irc            open      UnrealIRCd
10.1.163.125  8022   tcp    oa-system      filtered
10.1.163.125  8181   tcp    http           open      WEBrick httpd 1.3.1 Ruby 2
3.7 (2018-03-28)
10.1.163.125  8484   tcp    unknown        filtered
10.1.163.125  8585   tcp                   filtered
10.1.163.125  9200   tcp    wap-wsp        filtered
10.1.163.125  49153  tcp    unknown        filtered
10.1.163.125  49154  tcp    unknown        filtered
10.1.163.125  49202  tcp    unknown        filtered
```

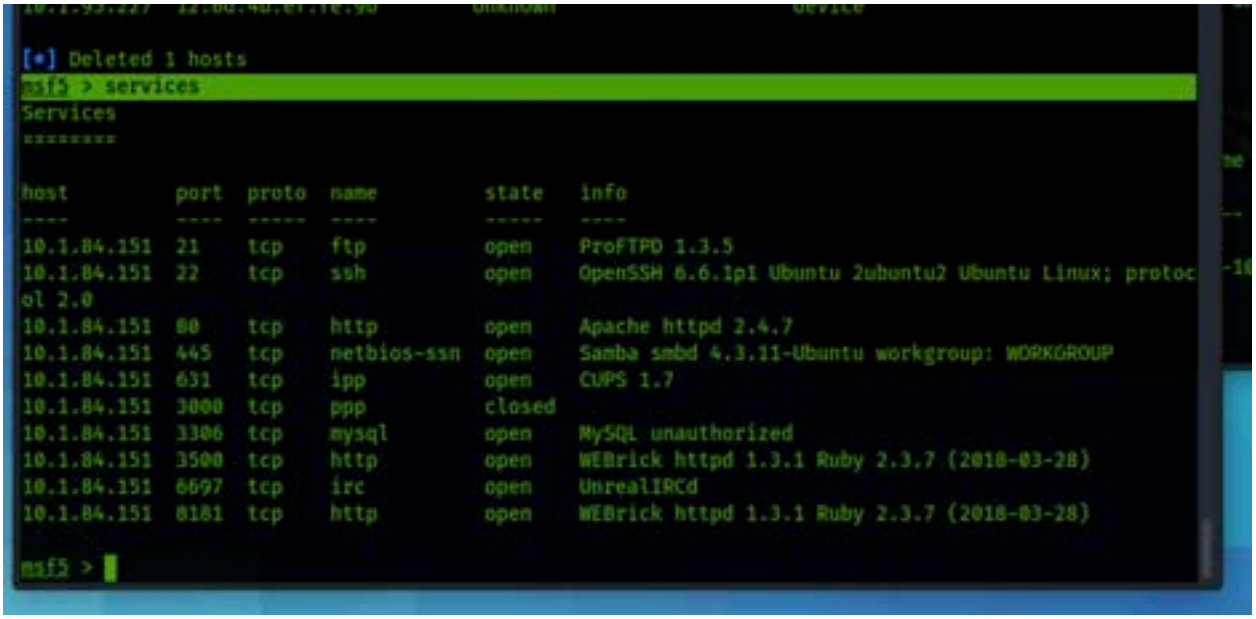

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)



5. References:

https://www.aelius.com/njh/subnet_sheet.html
https://nmap.org/book/nse-usage.html
https://nmap.org/nsedoc/categories/default.html

© 2021 Cyber Range. Created by R. Eric Kiser. (CC BY-NC-SA 4.0)